

IQRASEC ACADEMY

WEB APPLICATION PENETRATION TESTING (WAPT/VAPT) INTERNSHIP

Task 2: RECONNAISSANCE & ENUMERATION

Phase 1: Practical Web Security

Sudip Kumar Chaurasiya

Internship: IqraSec Academy - WAPT/VAPT Internship

Date: 15 October 2026

2. Concept / Understanding

Technology Identification

Technology identification helps determine what technologies are being used by a web application, such as web servers, frameworks, programming languages, and other components.

Subdomains

Subdomains are additional domains under a main domain. Finding subdomains can help identify additional services or web applications.

Directories and Endpoints

Directories and endpoints are locations or resources available on a web application. Discovering them can provide more information about the application's structure.

Parameters

Parameters are inputs sent to an application through requests. They may affect how the application processes information.

Login Pages

Finding login pages is useful during reconnaissance because authentication functionality may contain important application features and security controls.

API Endpoints

API endpoints allow applications to communicate and exchange information. Identifying API endpoints can help understand how different parts of an application work.

Hidden Functionality

Some functionality may not be directly visible through the main website. Reconnaissance and content discovery techniques can help identify these resources.

Basic Information Gathering

Information gathering is an important early stage of security testing because it helps create an understanding of the target before further testing.

3. Practical Work

Room 1: Passive Reconnaissance

I completed the Passive Reconnaissance room and learned how publicly available information can be collected without directly interacting with the target.

I studied methods for identifying information such as domains, subdomains, technologies, and other publicly available details.

```
Session Actions Edit View Help
+-----+
(kali@kali)-[~]
$ whois tryhackme.com
Domain Name: TRYHACKME.COM
Registry Domain ID: 2282723194_DOMAIN_COM-VRSN
Registrar WHOIS Server: whois.namecheap.com
Registrar URL: http://www.namecheap.com
Updated Date: 2025-05-11 14:00:02Z
Creation Date: 2018-07-05T19:46:15Z
Registry Expiry Date: 2034-07-05T19:46:15Z
Registrar: NameCheap, Inc.
Registrar IANA ID: 1068
Registrar Abuse Contact Email: abuse@namecheap.com
Registrar Abuse Contact Phone: +1.6613102107
Domain Status: clientTransferProhibited https://icann.org/epp#clientTransferProhibited
Name Server: KIP.NS.CLOUDFLARE.COM
Name Server: GMA.NS.CLOUDFLARE.COM
DNSSEC: unsigned
URL of the ICANN Whois Inaccuracy Complaint Form: https://www.icann.org/wicf/
>>> Last update of whois database: 2026-10-02T10:09:13Z <<<

For more information on Whois status codes, please visit https://icann.org/epp

NOTICE: The expiration date displayed in this record is the date the
registrar's sponsorship of the domain name registration in the registry is
currently set to expire. This date does not necessarily reflect the expiration
date of the domain name registrant's agreement with the sponsoring
registrar. Users may consult the sponsoring registrar's Whois database to
view the registrar's reported date of expiration for this registration.

TERMS OF USE: You are not authorized to access or query our Whois
database through the use of electronic processes that are high-volume and
automated except as reasonably necessary to register domain names or
modify existing registrations; the Data in VeriSign Global Registry
Services' ("VeriSign") Whois database is provided by VeriSign for
information purposes only, and to assist persons in obtaining information
```

- Redirection chain (Verisign to registrar server).
- Dates: useful for estimating company age or identifying renewal phishing windows.
- Name servers: potential new targets (if in scope).
- Status: locked domains (e.g., `clientTransferProhibited`) are harder to hijack.

- <https://whois.icann.org/> (legacy WHOIS)
- <https://lookup.icann.org/> (modern RDAP-focused lookup)
- <https://www.whoxy.com/> (historical WHOIS snapshots, free limited use)

Answer the questions below

20180705

namecheap.com

cloudflare.com

[illegible]

Room completed: 100%			
TOP PORTS	TOP ORGANIZATIONS	TOP COUNTRIES	TOP SERVICES
443 80	Amazon Data Services Ireland Limited Amazon.com, Inc.	United States Germany	Apache/2.4.18 (Ubuntu) WordPress/4.7.4 PHP/5.6.35-0ubuntu0.16.04.1 MySQL/5.7.18-0ubuntu0.16.04.1 Nginx/1.10.3 (Ubuntu)

Search Tips

Shodan supports a range of search filters for narrowing results:

- `hostname:tryhackme.com` matches a specific hostname.
- `org:"tryhackme"` filters by organisation name.
- `port:443 country:US` filters by port and country.
- `http.component:"wordpress"` identifies technology stack (if exposed).

For the full reference, see: <https://help.shodan.io/the-basics/search-query-fundamentals>

For further exploration, [Censys.io](https://censys.io) (free basic searches) provides similar host and certificate data. It can serve as a useful complement when cross-referencing results.

Exercise

1. Go to `https://www.shodan.io` (no account needed for basic searches).
2. Search one of `tryhackme.com`'s IPs (from Task 4, e.g., `104.26.10.229`) or use `hostname:tryhackme.com`.
3. Explore the results: note the provider (Cloudflare), location (US), open ports (443/HTTPS is common), and banners.

Use Shodan to answer the questions below. All answers are visible without a premium account.

Answer the questions below

According to Shodan.io, what is the first country in the world in terms of the number of publicly accessible Apache servers?

✓ Correct Answer

0

Based on Shodan.io, what is the 3rd most common port used for Apache?

✓ Correct Answer

0

Based on Shodan.io, what is the most common port used for nginx?

✓ Correct Answer

0

```
(kali@kali)-[~]
$ dig @1.1.1.1 thmlabs.com TXT
; <<>> DiG 9.20.29-1-Debian <<>> @1.1.1.1 thmlabs.com TXT
; (1 server found)
;; global options: +cmd
;; Got answer:
;; -->HEADER<-- opcode: QUERY, status: NOERROR, id: 28869
;; flags: qr rd ra; QUERY: 1, ANSWER: 1, AUTHORITY: 0, ADDITIONAL: 1
;; OPT PSEUDOSECTION:
; EDNS: version: 0, flags:; udp: 1232
;; QUESTION SECTION:
;thmlabs.com.                IN      TXT
;; ANSWER SECTION:
thmlabs.com.                 300     IN      TXT      "THM{a5b83929888ed36acb0272971e438d78}"
;; Query time: 231 msec
;; SERVER: 1.1.1.1#53(1.1.1.1) (UDP)
;; WHEN: Fri Oct 02 06:25:35 EDT 2026
;; MSG SIZE rcvd: 90
(kali@kali)-[~]
```

```
user@TryHackMe$ dig @1.1.1.1 tryhackme.com MX

; <<>> DiG 9.18.28-0ubuntu0.22.04.1-Ubuntu <<>> @1.1.1.1 tryhackme.com MX
; (1 server found)
;; global options: +cmd
;; Got answer:
;; ->>HEADER<<- opcode: QUERY, status: NOERROR, id: 12345
;; flags: qr rd ra; QUERY: 1, ANSWER: 5, AUTHORITY: 0, ADDITIONAL: 1

;; ANSWER SECTION:
tryhackme.com. 300 IN MX 1 aspmx.l.google.com.
tryhackme.com. 300 IN MX 5 alt1.aspmx.l.google.com.
tryhackme.com. 300 IN MX 5 alt2.aspmx.l.google.com.
tryhackme.com. 300 IN MX 10 alt3.aspmx.l.google.com.
tryhackme.com. 300 IN MX 10 alt4.aspmx.l.google.com.

;; Query time: 28 msec
;; SERVER: 1.1.1.1#53(1.1.1.1) (UDP)
;; WHEN: Mon Jan 26 22:00:00 UTC 2026
;; MSG SIZE rcvd: 152
```

Privacy tip: Use public resolvers like `1.1.1.1` (which supports DNS over HTTPS and DNS over TLS) to avoid your ISP logging your queries.

Defender note: Monitor for unexpected DNS changes (new MX records, rogue TXT entries). These can be signs of subdomain takeover or configuration errors.

On the AttackBox, open a terminal and use `nslookup` or `dig` (recommended) to answer the following questions.

Answer the questions below

Check the TXT records of thmlabs.com. What is the flag there?

THM{a5b83929888ed36acb0272971e438d78}

✓ Correct Answer

Room 2: Active Reconnaissance

I completed the Active Reconnaissance room. I practiced techniques that involve directly interacting with a target to collect information.

I learned about techniques such as ping, traceroute, and other basic methods used to understand a target.

```
1 let step = 1;
2 let questions = [
3   {
4     'speaking' : 'alice',
5     'answer_1' : 'SYN : Can you hear me Bob?',
6     'answer_2' : 'FIN : Goodbye',
7     'answer_3' : 'ACK : Erm... What?',
8     'answer' : 1
9   },
10  {
11    'speaking' : 'bob',
12    'answer_1' : 'RST : Cya Later',
13    'answer_2' : 'PING : 77',
14    'answer_3' : 'SYN/ACK : Yes, I can hear you!',
15    'answer' : 3
16  },
17  {
18    'speaking' : 'alice',
19    'answer_1' : 'FAIL : SEGMENTATION FAULT',
20    'answer_2' : 'ACK : Okay Great',
21    'answer_3' : 'SYN : x = 3?',
22    'answer' : 2
23  },
24  {
25    'speaking' : 'alice',
```

Room completed: 100%

Active machines information

IP Address: 10.48.141.63

CMS

[WordPress](#)

Analytics

[Google Analytics](#)

Blogs

[WordPress](#)

Miscellaneous

[HTTP/2](#)

Web servers

[Apache](#) 2.4.6

Programming languages

Operating systems

[CentOS](#)

CDN

[Cloudflare](#)

Marketing automation

[MailChimp](#)

Databases

[MySQL](#)

Advertising

[Google AdSense](#)

Email

Other useful alternatives include **BuiltWith Technology Profiler**, which is similar to Wappalyzer but sometimes detects different technologies, **WhatRuns** as a lightweight alternative, and **Library Detector for Chrome/Firefox**, which focuses specifically on JavaScript libraries and frameworks. Over time, most people settle on a small set of three to five extensions that best match their workflow.

Even though browsing appears normal, unusual patterns can still trigger behavioural rules in modern WAFs or endpoint detection systems. Rapid page loads, modified headers, frequent DevTools usage, and abnormal User-Agent strings are all signals that defenders look for. The goal is to mimic legitimate user behaviour whenever possible.

Answer the questions below

Browse to the [following website \(opens in new tab\)](#) and ensure that you have opened your Developer Tools on AttackBox Firefox, or the browser on your computer. Using the Developer Tools, figure out the total number of questions.

8

✓ Correct Answer

0

```
Applications Places System Fri Oct 2, 10:56
root@ip-10-48-170-26:~
File Edit View Search Terminal Help
root@ip-10-48-170-26:~# ping -c 4 10.48.141.83
PING 10.48.141.83 (10.48.141.83) 56(84) bytes of data.
64 bytes from 10.48.141.83: icmp_seq=1 ttl=64 time=0.651 ms
64 bytes from 10.48.141.83: icmp_seq=2 ttl=64 time=0.190 ms
64 bytes from 10.48.141.83: icmp_seq=3 ttl=64 time=0.200 ms
64 bytes from 10.48.141.83: icmp_seq=4 ttl=64 time=0.243 ms

--- 10.48.141.83 ping statistics ---
4 packets transmitted, 4 received, 0% packet loss, time 3072ms
rtt min/avg/max/mdev = 0.190/0.321/0.651/0.191 ms
root@ip-10-48-170-26:~#
```

```
root@ip-10-48-170-26:~# ping -c 10 10.48.141.83
PING 10.48.141.83 (10.48.141.83) 56(84) bytes of data.
64 bytes from 10.48.141.83: icmp_seq=1 ttl=64 time=0.282 ms
64 bytes from 10.48.141.83: icmp_seq=2 ttl=64 time=0.460 ms
64 bytes from 10.48.141.83: icmp_seq=3 ttl=64 time=0.211 ms
64 bytes from 10.48.141.83: icmp_seq=4 ttl=64 time=0.259 ms
64 bytes from 10.48.141.83: icmp_seq=5 ttl=64 time=0.275 ms
64 bytes from 10.48.141.83: icmp_seq=6 ttl=64 time=0.237 ms
64 bytes from 10.48.141.83: icmp_seq=7 ttl=64 time=0.335 ms
64 bytes from 10.48.141.83: icmp_seq=8 ttl=64 time=0.283 ms
64 bytes from 10.48.141.83: icmp_seq=9 ttl=64 time=0.447 ms
64 bytes from 10.48.141.83: icmp_seq=10 ttl=64 time=0.466 ms

--- 10.48.141.83 ping statistics ---
10 packets transmitted, 10 received, 0% packet loss, time 9254ms
rtt min/avg/max/mdev = 0.211/0.325/0.466/0.091 ms
root@ip-10-48-170-26:~#
```

```
30 * * *
root@ip-10-48-170-26:~# telnet 10.48.141.83 80
Trying 10.48.141.83...
Connected to 10.48.141.83.
Escape character is '^]'.
GET / HTTP/1.1
host: telnet
HTTP/1.1 408 Request Timeout
Date: Fri, 02 Oct 2026 11:23:11 GMT
Server: Apache/2.4.61 (Debian)
Content-Length: 330
Connection: close
Content-Type: text/html; charset=iso-8859-1

<!DOCTYPE HTML PUBLIC "-//IETF//DTD HTML 2.0//EN">
<html><head>
<title>408 Request Timeout</title>
</head><body>
<h1>Request Timeout</h1>
<p>Server timeout waiting for the HTTP request from the client.</p>
<hr>
<address>Apache/2.4.61 (Debian) Server at ip-10-48-141-83.ap-south-1.compute.interna
l Port 80</address>
</body></html>
Connection closed by foreign host.
root@ip-10-48-170-26:~#
```

Room completed: 100%

```
HTTP/1.1 200 OK
Server: nginx/1.6.2
Date: Tue, 17 Aug 2021 11:13:25 GMT
Content-Type: text/html
Content-Length: 867
Last-Modified: Tue, 17 Aug 2021 11:12:16 GMT
Connection: keep-alive
ETag: "611b9990-363"
Accept-Ranges: bytes
...
```

The field of interest here is `Server: nginx/1.6.2`, which reveals the type and version of the web server software. This is exactly the kind of information that active reconnaissance aims to uncover. Software versions can be cross-referenced against known vulnerabilities in databases such as CVE and Exploit-DB.

This same banner-grabbing technique works against any TCP-based service. If you connect to a mail server, you would use SMTP or POP3 commands instead of HTTP. If you connect to an FTP server on port 21, the server typically sends its banner immediately upon connection without requiring any commands at all. The underlying principle is always the same. Connect to the port, read what the server sends back, and optionally issue protocol-specific commands to extract further information.

In modern environments, many services enforce encryption. For example, SMTPS runs on port 465, and HTTPS runs on port 443. Telnet cannot handle encrypted connections. For HTTPS, use `curl --head https://MACHINE_IP` or `openssl s_client -connect MACHINE_IP:443`. For other TLS-wrapped services, `openssl s_client` or `ncat --ssl` are the appropriate tools.

Answer the questions below

Start the attached VM from Task 3 if it is not already started. On the AttackBox, open the terminal and use the telnet client to connect to the VM on port 80. What is the name of the running server?

✓ Correct Answer

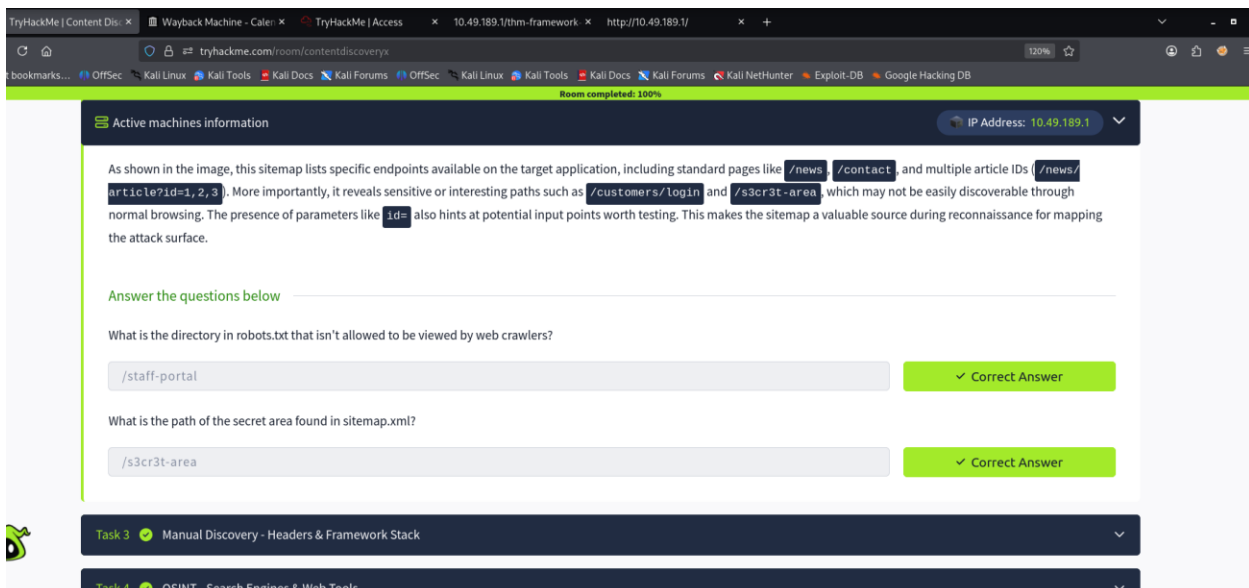
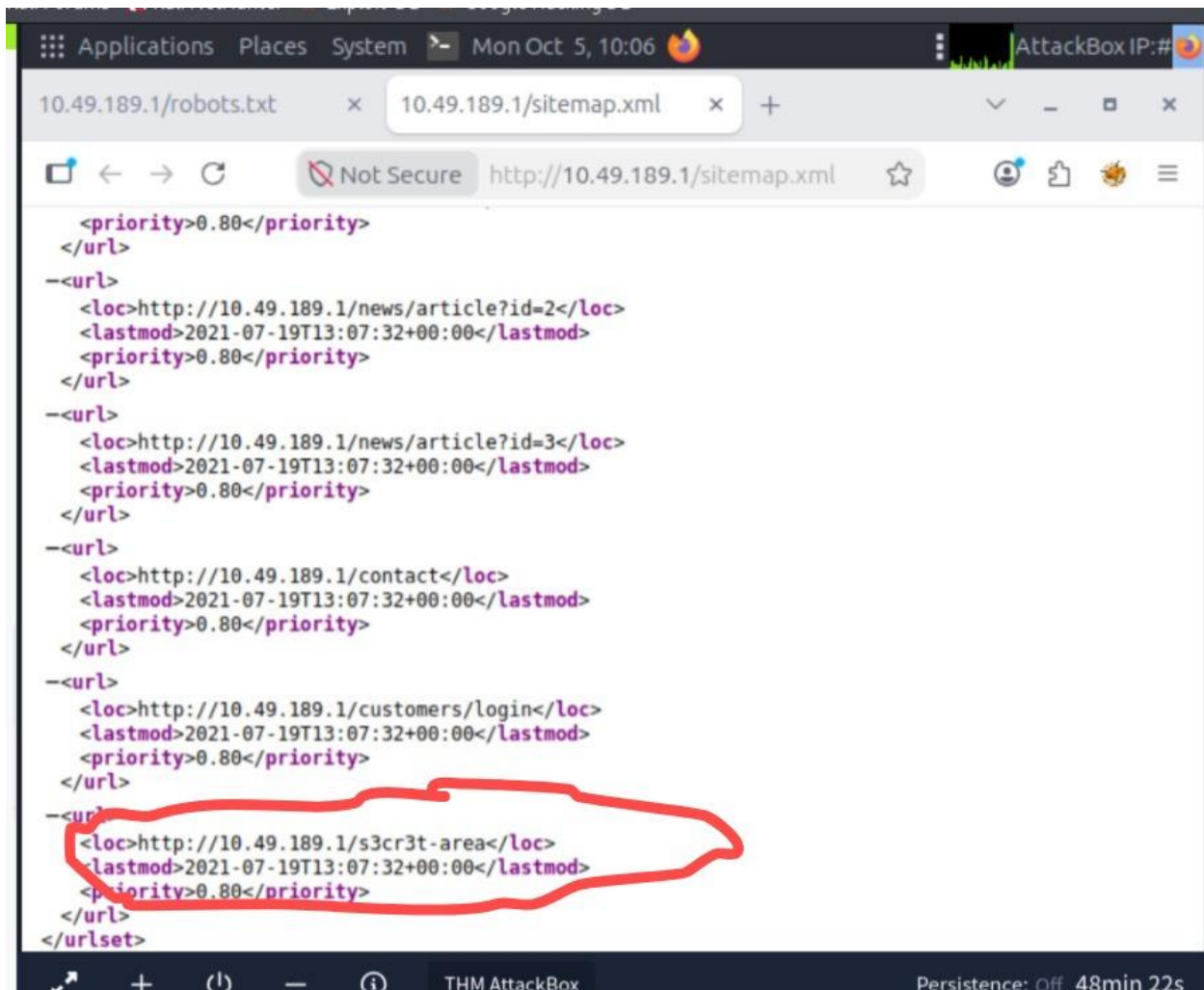
What is the version of the running server (on port 80 of the VM)?

✓ Correct Answer

Room 3: Content Discovery

I completed the Content Discovery room. I learned how directories, files, endpoints, login pages, parameters, and hidden resources can be discovered.

This helped me understand how a web application's attack surface can be larger than what is visible on the main page.



```

28         <ul class="nav navbar-nav">
29             <li class="active"><a href="/">Home</a></li>
30             <li><a href="/news">News</a></li>
31             <li><a href="/contact">Contact</a></li>
32             <li><a href="/customers">Customers</a></li>
33         </ul>
34     </div><!--/.nav-collapse -->
35 </div>
36 </nav><div class="container" style="padding-top:60px">
37     <h1 class="text-center">Acme IT Support</h1>
38     <div class="row">
39         <div class="col-md-8 col-md-offset-2 text-center">
40             
41             <p class="welcome-msg">Our dedicated staff are ready <a href="/secret-page">to</a> assist you with your IT problems.</p>
42         </div>
43     </div>
44 </div>
45 <script src="/assets/jquery.min.js"></script>
46 <script src="/assets/bootstrap.min.js"></script>
47 <script src="/assets/site.js"></script>
48 </body>
49 </html>
50 <!--

```

static-labs.tryhackme.cloud/sites/thm-web-framework/documentation.html

Kali Linux Kali Tools Kali Docs Kali Forums OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB



THM Web Framework

Documentation

[Home](#) • [Change Log](#) • [Documentation](#)

Documentation

The documentation for the framework is pre-installed on your websites administration portal.

Once you've installed the framework navigate to the [/thm-framework-login](#) path on your website.

You can login with the username **admin** and password **admin** (make sure you change this password)

Not Secure http://10.49.189.1/thm-framework-login

Import bookmarks... OffSec Kali Linux Kali Tools Kali Docs Kali Forums OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB

THM Web Framework

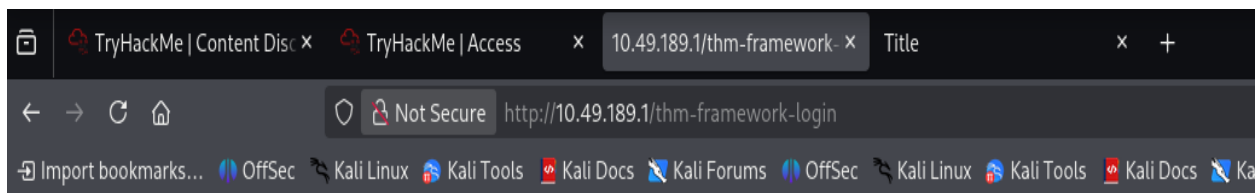
Login

Login

Username:

Password:

Login



THM{CHANGE_DEFAULT_CREDENTIALS}

```
kali@kali:~$ gobuster vhost -u "http://10.49.189.1" --domain acmeitsupport.thm --wordlist /usr/share/wordlists/seclists/Discovery/DNS/subdomains-top1million-5000.txt --append-domain --exclude-length 250-320

Gobuster v3.8.2
by DJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://10.49.189.1
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/seclists/Discovery/DNS/subdomains-top1million-5000.txt
[+] User Agent: gobuster/3.8.2
[+] Timeout: 10s
[+] Append Domain: true
[+] Exclude Length: 250-320
[+] Exclude Hostname Length: false

Starting gobuster in vhost enumeration mode
blog.acmeitsupport.thm Status: 200 [Size: 58]
admin.acmeitsupport.thm Status: 200 [Size: 66]
shop.acmeitsupport.thm Status: 200 [Size: 56]
Progress: 977 / 4989 (19.58%)
```

Room completed: 100%

Active machines information

IP Address: 10.49.189.1

Review the results and identify the virtual hosts responding with a `200 OK` status. Access each one in your browser to explore what's hosted there.

As shown in the above output, a virtual host enumeration was performed using Gobuster to identify hidden subdomains associated with the target. The scan used a large wordlist and filtered out common response lengths to reduce noise, focusing only on meaningful results. However, no valid virtual hosts were discovered during the scan, indicating that there are likely no additional subdomains configured for this application. This suggests that further testing should focus on the main domain and the identified directories.

Answer the questions below

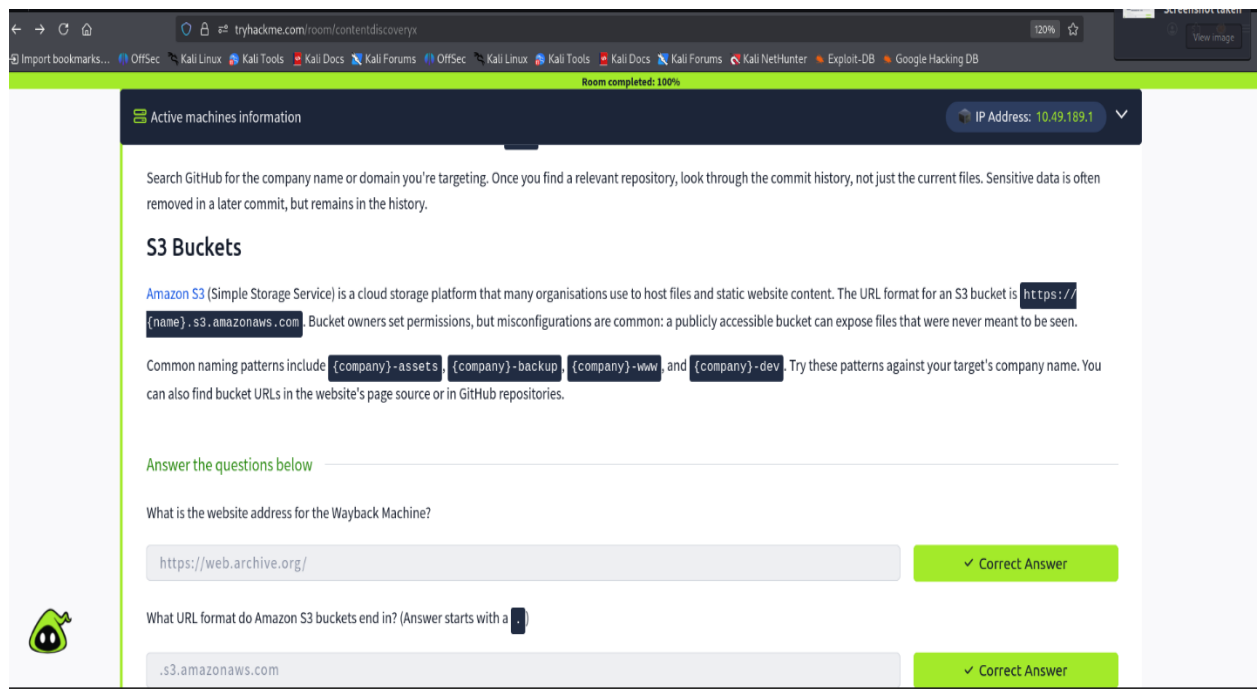
Apart from `dns` and `-w`, which shorthand flag is required for dns mode?

✓ Correct Answer

How many virtual hosts on `acmeitsupport.thm` respond with status code 200?

✓ Correct Answer

Task 8 ✓ Conclusion



- TryHackMe
- Web Browser

- Ping
- Traceroute
- Basic reconnaissance techniques
- Content discovery techniques

5. Evidence

The evidence for this task includes:

- Passive Reconnaissance practical screenshot.
- Active Reconnaissance practical screenshot.
- Content Discovery practical screenshot.
- TryHackMe completion/progress screenshots.

Passive Reconnaissance completion

← Back to all walkthroughs

Passive Reconnaissance

Learn about the essential tools for passive reconnaissance, such as whois, nslookup, and dig.

📶 🌐 ⌚ 60 min 👤 276,123 🏆 🚀

[Share your achievement](#)
[Start AttackBox](#)
[Save Room](#)
[5336 Recommend](#)
[Connectivity](#)
[Options](#)

Room completed: 100%

- Task 1 Introduction
- Task 2 Passive Versus Active Recon
- Task 3 Whois
- Task 4 nslookup and dig
- Task 5 DNSDumpster
- Task 6 Shodan.io
- Task 7 Summary

Active Reconnaissance completion

user [Set as default](#)

← Back to all walkthroughs

Active Reconnaissance

Learn how to use simple tools such as traceroute, ping, telnet, and a web browser to gather information.

📶 📶 ⌚ 60 min 👤 215,944 🗨️

[Share your achievement](#) [Start AttackBox](#) [Save Room](#) [3781 Recommend](#) [Connectivity](#) [Options](#)

Room completed: 100%

Active machines information IP Address: 10.49.180.146

- Task 1 Introduction
- Task 2 Web Browser
- Task 3 Ping
- Task 4 Traceroute
- Task 5 Telnet
- Task 6 Netcat
- Task 7 Putting It All Together

Content Discovery completion

TryHackMe Dashboard Learn Practice Compete

🔍 🔔 Upgrade 37 5 C

← Back to all walkthroughs

Content Discovery

Discover hidden web content using manual techniques, OSINT, and Gobuster enumeration.

📶 📶 ⌚ 30 min 👤 19,487 🗨️

[Share your achievement](#) [Start AttackBox](#) [Save Room](#) [174 Recommend](#) [Connectivity](#) [Options](#)

Room completed: 100%

- Task 1 Introduction
- Task 2 Manual Discovery - Common Files
- Task 3 Manual Discovery - Headers & Framework Stack
- Task 4 OSINT - Search Engines & Web Tools
- Task 5 OSINT - Repositories & Archives
- Task 6 Automated Discovery - Gobuster Fundamentals
- Task 7 Automated Discovery - Subdomains & Virtual Hosts
- Task 8 Conclusion

6. Result

I successfully completed the three assigned reconnaissance and enumeration rooms.

I learned how to collect information using passive and active techniques and how content discovery can identify directories, endpoints, login pages, parameters and hidden functionality.

7. Key Learnings

- I learned the difference between passive and active reconnaissance.
- I learned about technology identification.
- I understood the importance of discovering subdomains.
- I learned how directories and endpoints can be identified.
- I learned about parameters and login pages.
- I understood the importance of API endpoint discovery.
- I learned that hidden functionality can increase the attack surface.
- I understood why reconnaissance is an important part of web application penetration testing.

TryHackMe Rooms Completed

Room 1 — Passive Reconnaissance

<https://tryhackme.com/room/passiverecon>

Room 2 — Active Reconnaissance

<https://tryhackme.com/room/activerecon>

Room 3 — Content Discovery

<https://tryhackme.com/room/contentdiscoveryx>

